

The background of the image features a dark blue gradient on the left, transitioning into a large, vibrant, abstract shape on the right. This shape is composed of overlapping curved segments in shades of orange, pink, and purple, creating a dynamic, modern aesthetic.

AWS re:Invent

NOV. 27 – DEC. 1, 2023 | LAS VEGAS, NV

SEC313-R

Shift left: A builder discussion

Nicholas Jaeger

(he/him)

Principal Security SA
Amazon Web Services

Niaz Khan

(he/him)

General Manager, AWS Signer
Amazon Web Services



Agenda

- 01 The state of secure software development
- 02 AWS tooling to support code scanning in early development
- 03 Ensuring code provenance and integrity

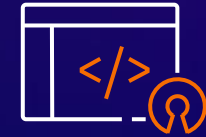
Challenges of quickly building reliable, secure code



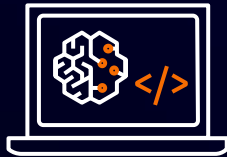
Shortage of developers



Time spent on undifferentiated code



Appropriate use of open source



Data privacy



Time spent learning technologies, APIs, and best practices



Write secure code

Open-source software (OSS) accelerates innovation

40M

Over 40 million OSS
components available¹

3.2M

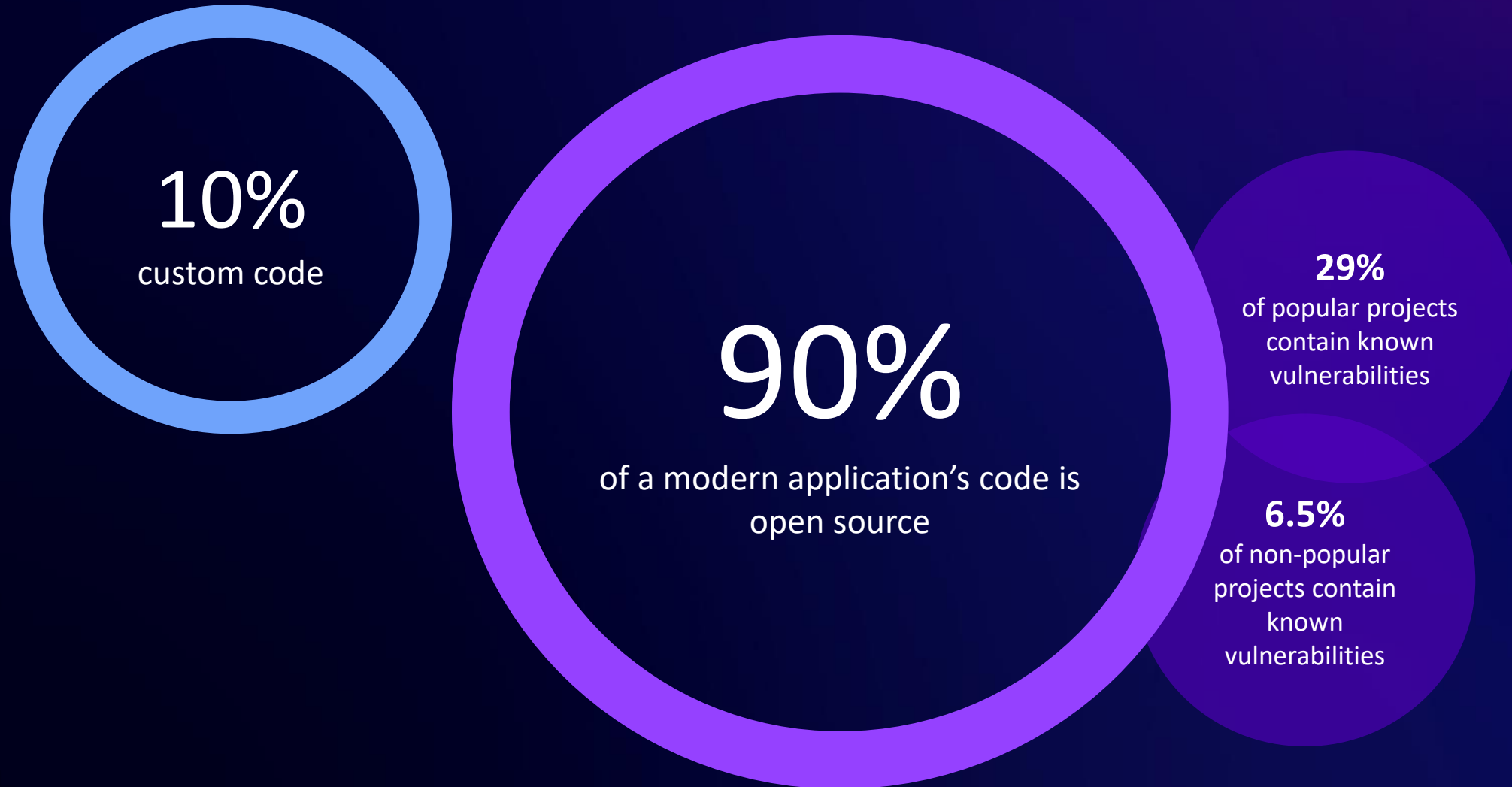
OSS projects
available by 2023²

3.1T

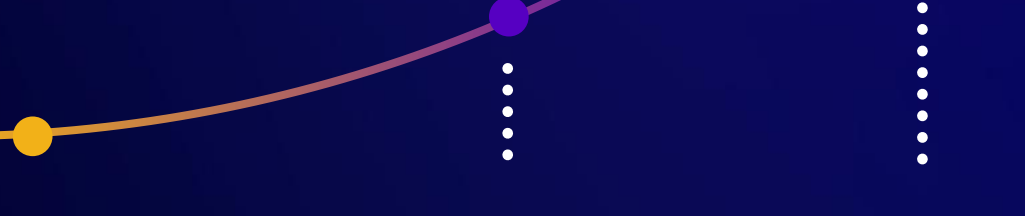
Annual request
volume³

^{1,2,3} Sonatype, 2023 State of the Software Supply Chain

Not all parts are created equal



Generative AI is here

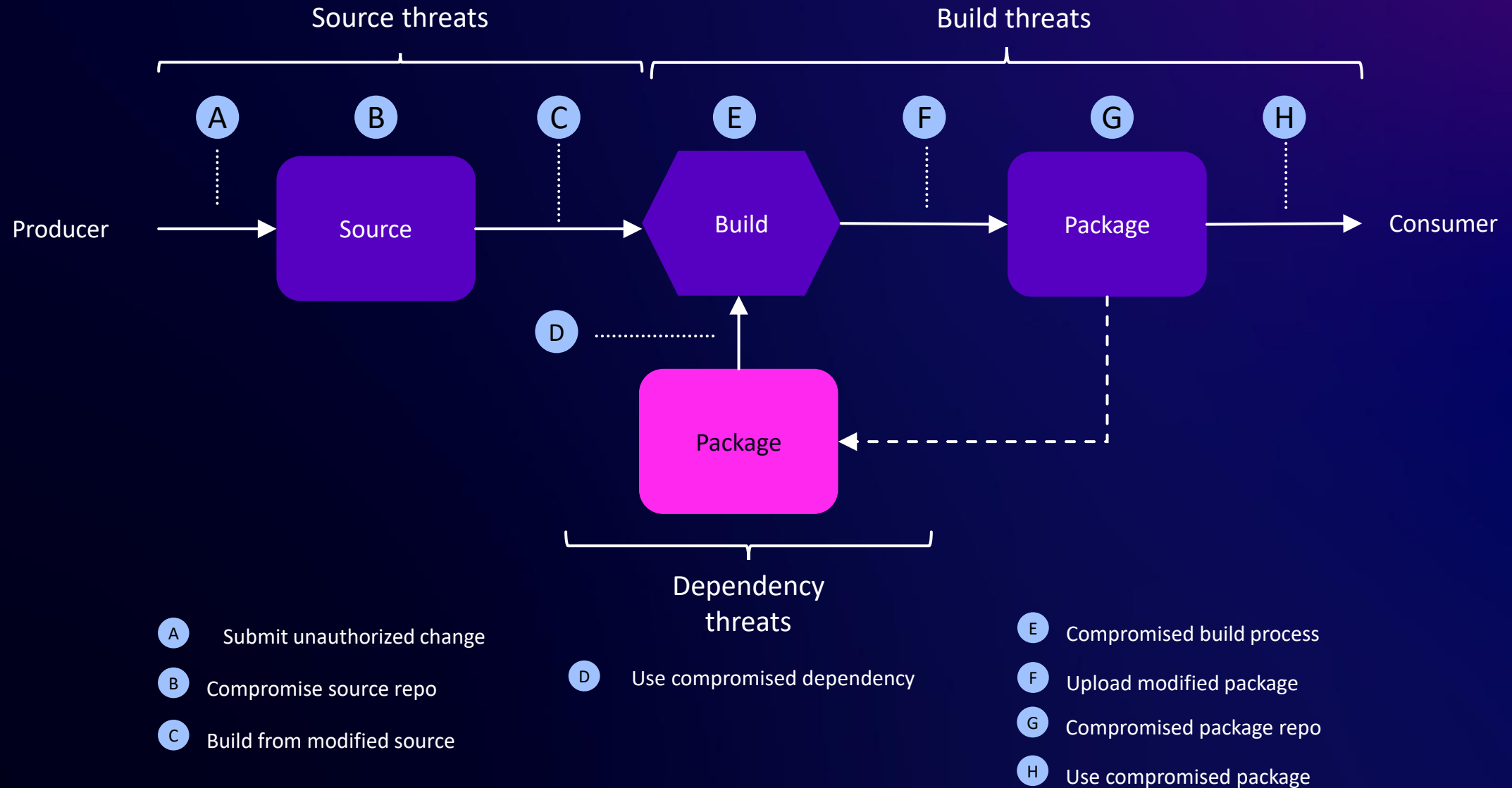


Massive proliferation
of data

Availability of scalable
compute capacity

Machine learning
innovation

Security threats in software development

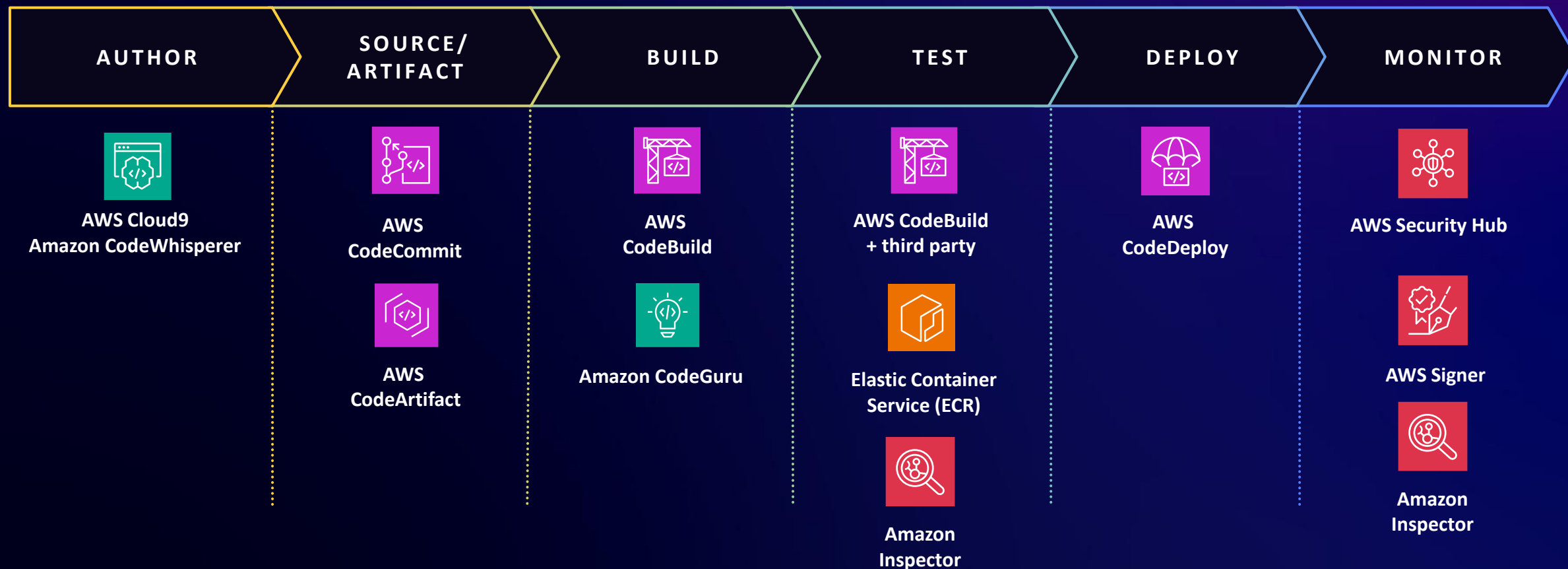


Security in development

- Start left
- Verify integrity between each step
- Review both custom and imported code
- Run static and dynamic testing
- Observability
- Automate everything



AWS services aligned to help ship secure software, faster



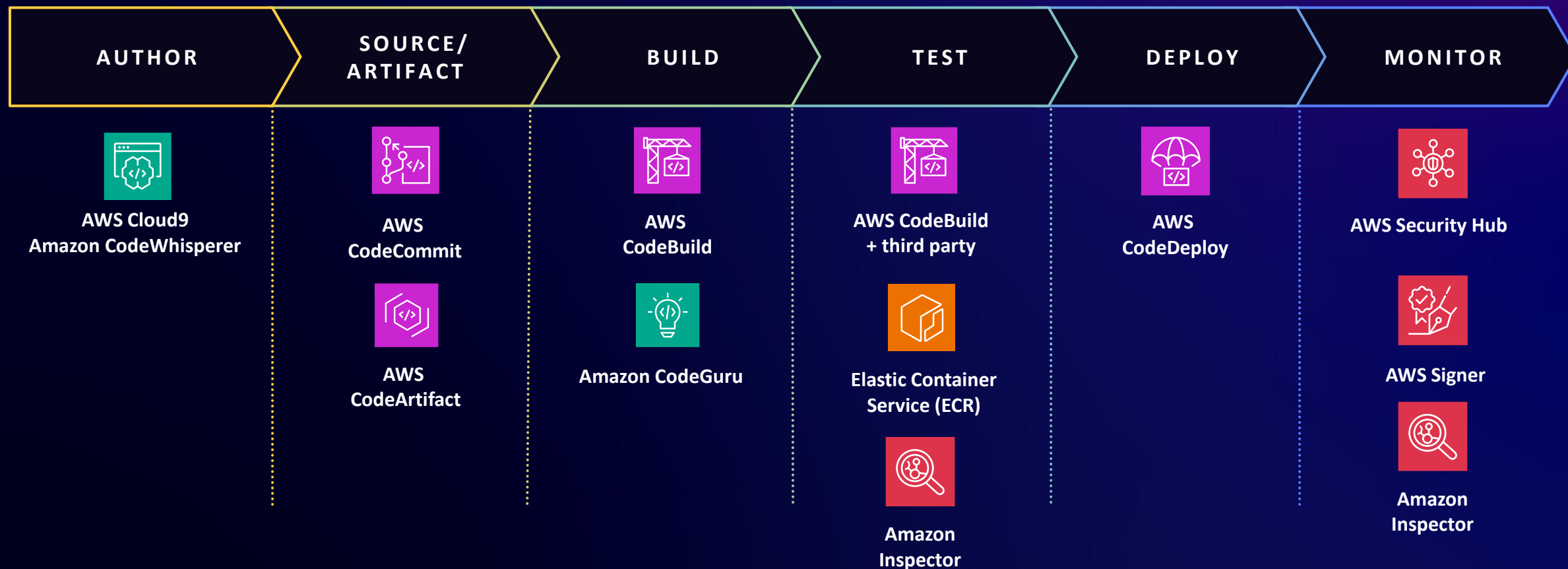
CodeWhisperer security scanning

- Scan generated and developer-written code to detect security vulnerabilities
- Receive vulnerability remediation suggestions
- Scan for hard-to-find security vulnerabilities
- Supports VS Code and JetBrains IDEs for Python, Java, and JavaScript

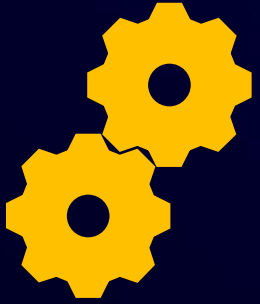
 **Security scan completed. 3 issues found.**

 <code>lambda_function.py</code>	<code>user/projects/lambda_function.py</code>
	Not setting the S3 bucket owner condition might introduce a risk of accidentally using a wrong bucket. For example, a configuration error lead to accidentally writing production data into test accounts. [Line 150]
	The elevated privilege level required to perform operations should be immediately after the operation is performed. [Line 160]
	Recreating AWS clients from scratch in each Lambda function invocation is expensive and can lead to availability risks. Clients should be cached across invocations. [Line 190]

AWS services aligned to help ship secure software, faster



CodeGuru Security features



Onboarding

Cloud-based API allows you to **integrate flexibly** at various stages of the CI/CD pipeline. Also scales with your workload so you don't need to manage capacity.



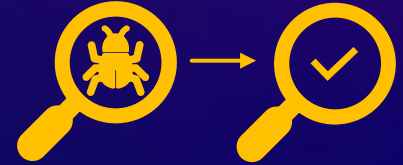
Triaging/Prioritization

Low false positives rate improves your operational efficiency as you have fewer findings to review.



Remediation

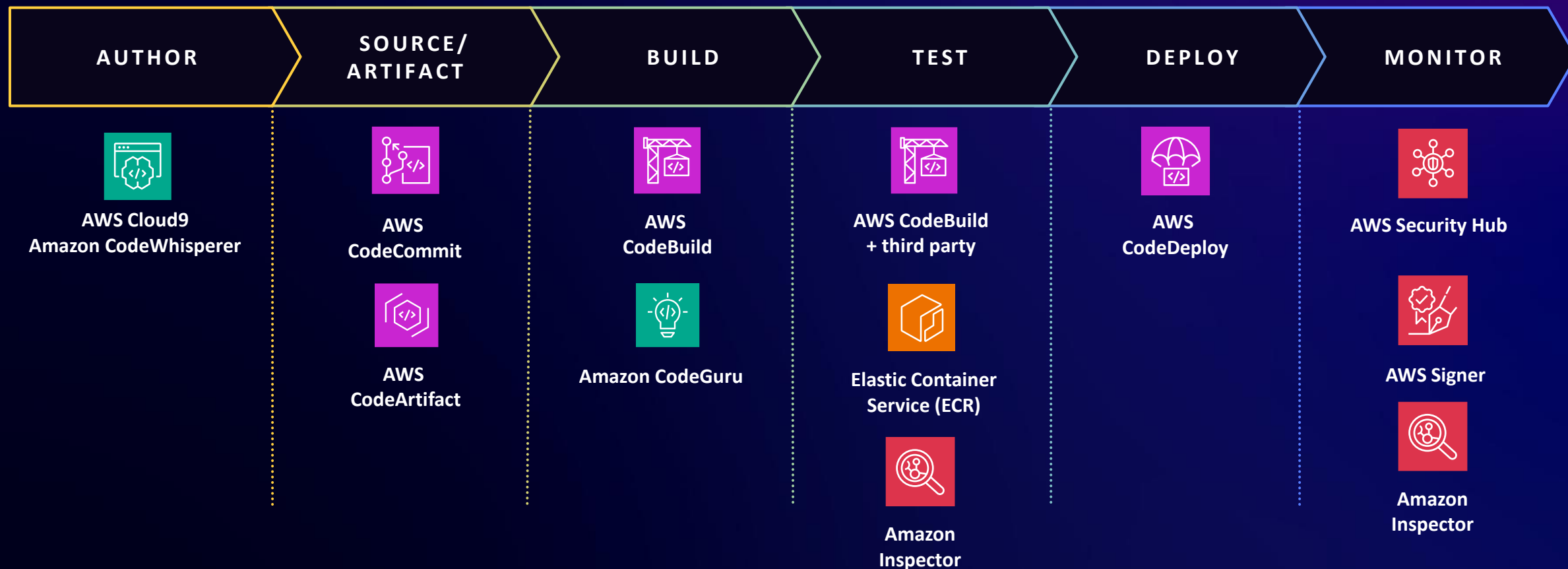
Fewer false positives means you get fewer tickets. Your dev teams can now allocate their limited resources to **actual vulnerabilities**.



Closure

Bug tracking **automatically detects and updates bug status**, providing current and accurate reporting on open vulnerabilities and closure rate.

AWS services aligned to help ship secure software, faster



How does code signing fit in?

Code signing is an industry **standard** technique used to confirm that the code is **unaltered** and comes from a **known** source.

It can be used to provide **assurance** that a **process** was run on the code earlier in the development cycle.



AWS Signer



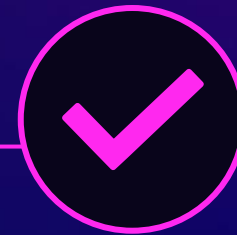
Validate code against a digital signature to confirm that the code is unaltered and from a trusted publisher.



Define your signing environment in a **single place**.

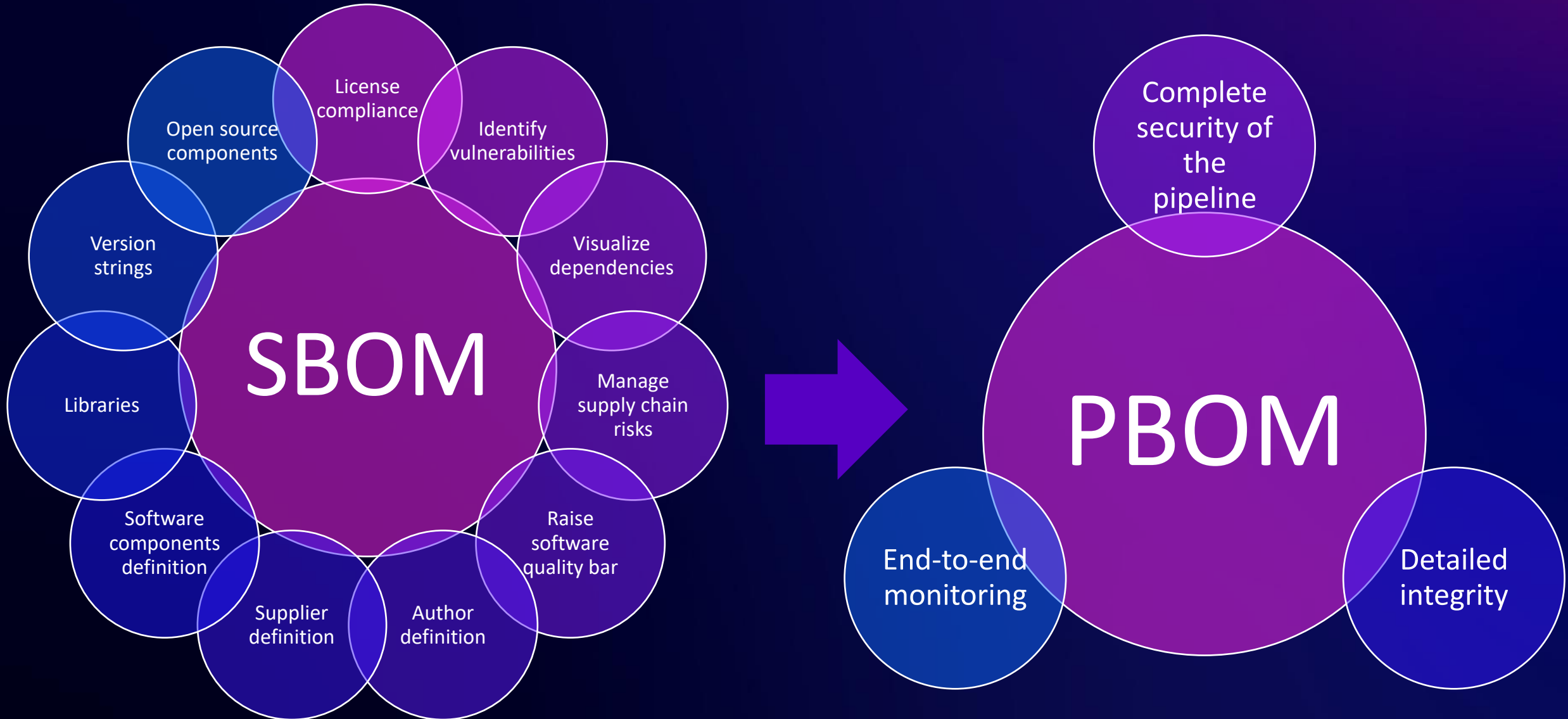


Manage the code-signing certificates and private and public keys.



Enable management of the code-signing lifecycle.

Why do we need SBOM?



Software bill of materials

A **software bill of material (SBOM)** is defined as a “nested inventory, a list of ingredients” that make up software components

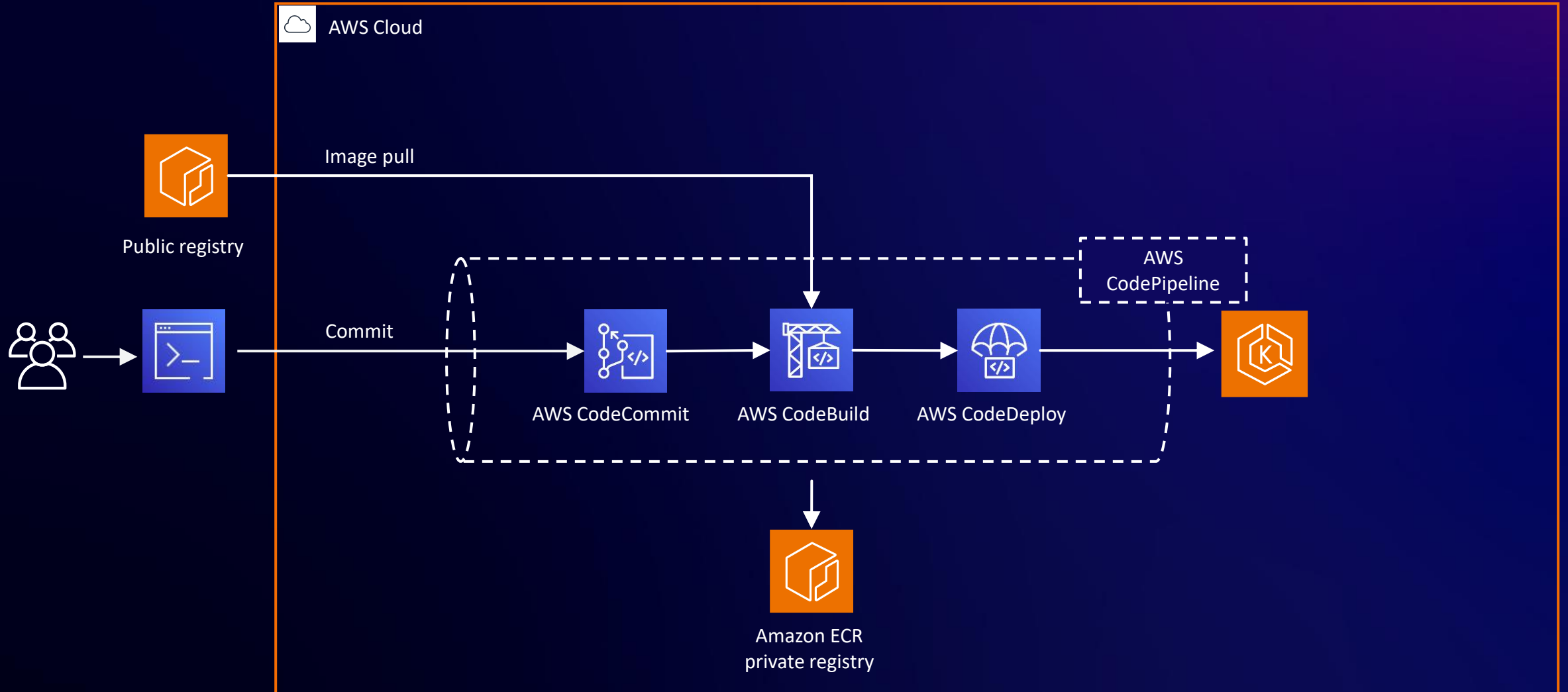


- ✓ SBOM formats supported: CycloneDx and SPDX
- ✓ SBOMs can be exported for the complete org or as granular as a resource
- ✓ Allows export for all resources being actively monitored by Amazon Inspector
- ✓ Includes both operating system (OS) packages and third-party programming language packages
- ✓ Free of cost

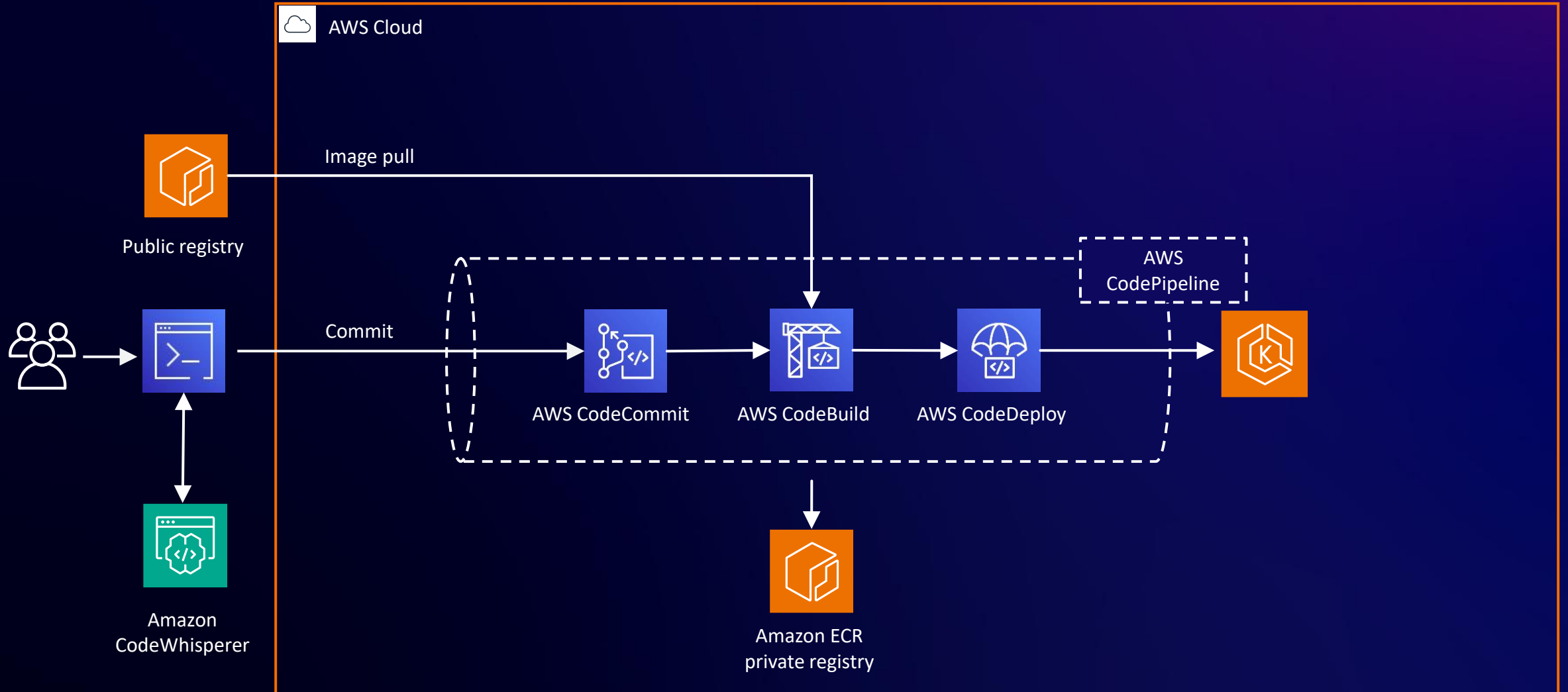
Architecture walkthrough



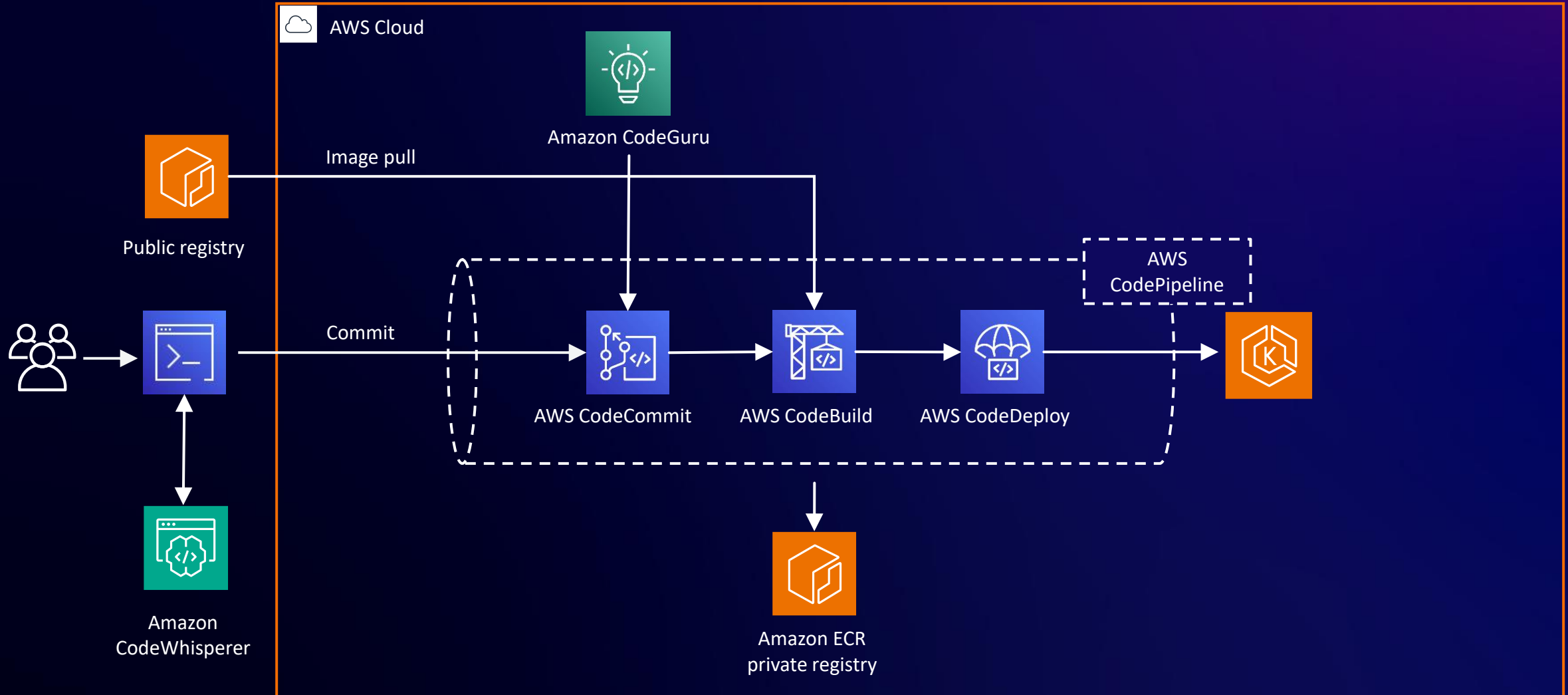
Security in development with AWS



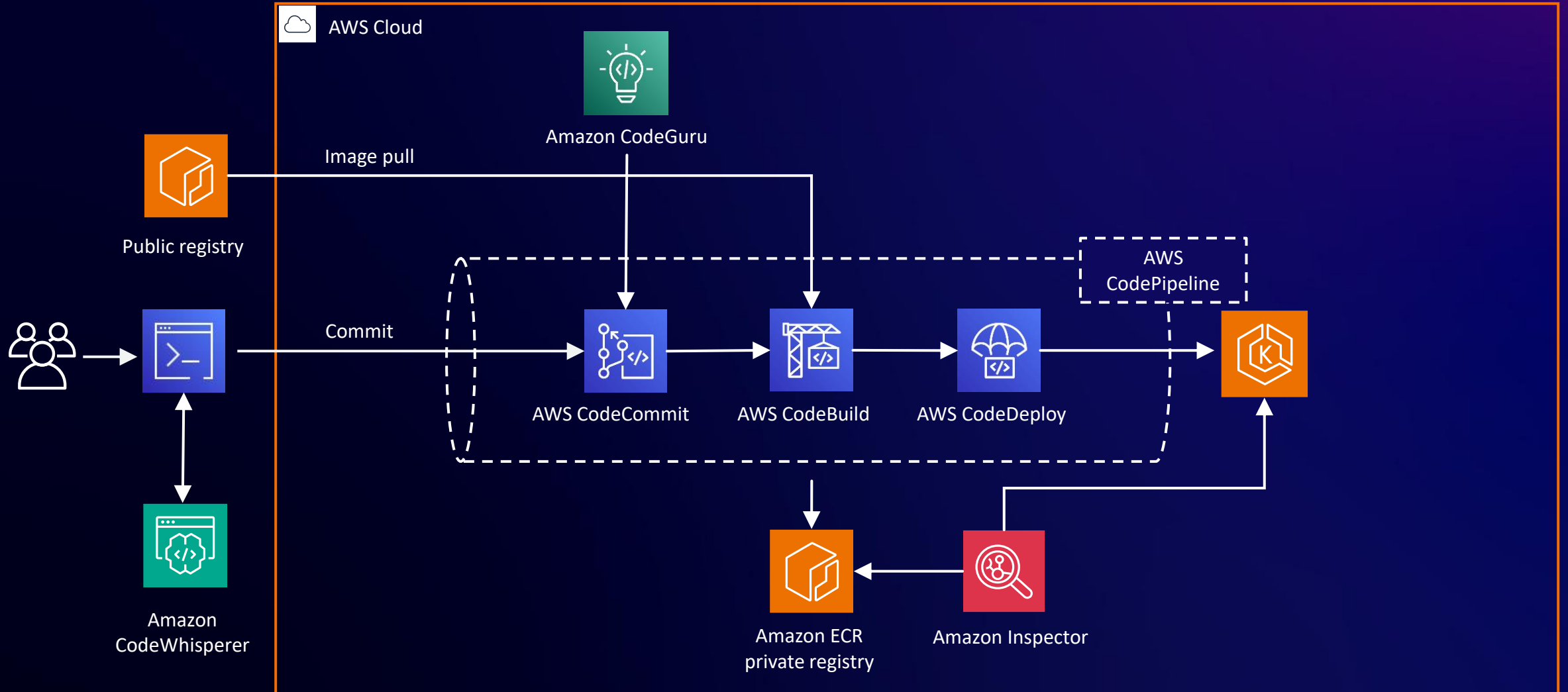
Security in development with AWS



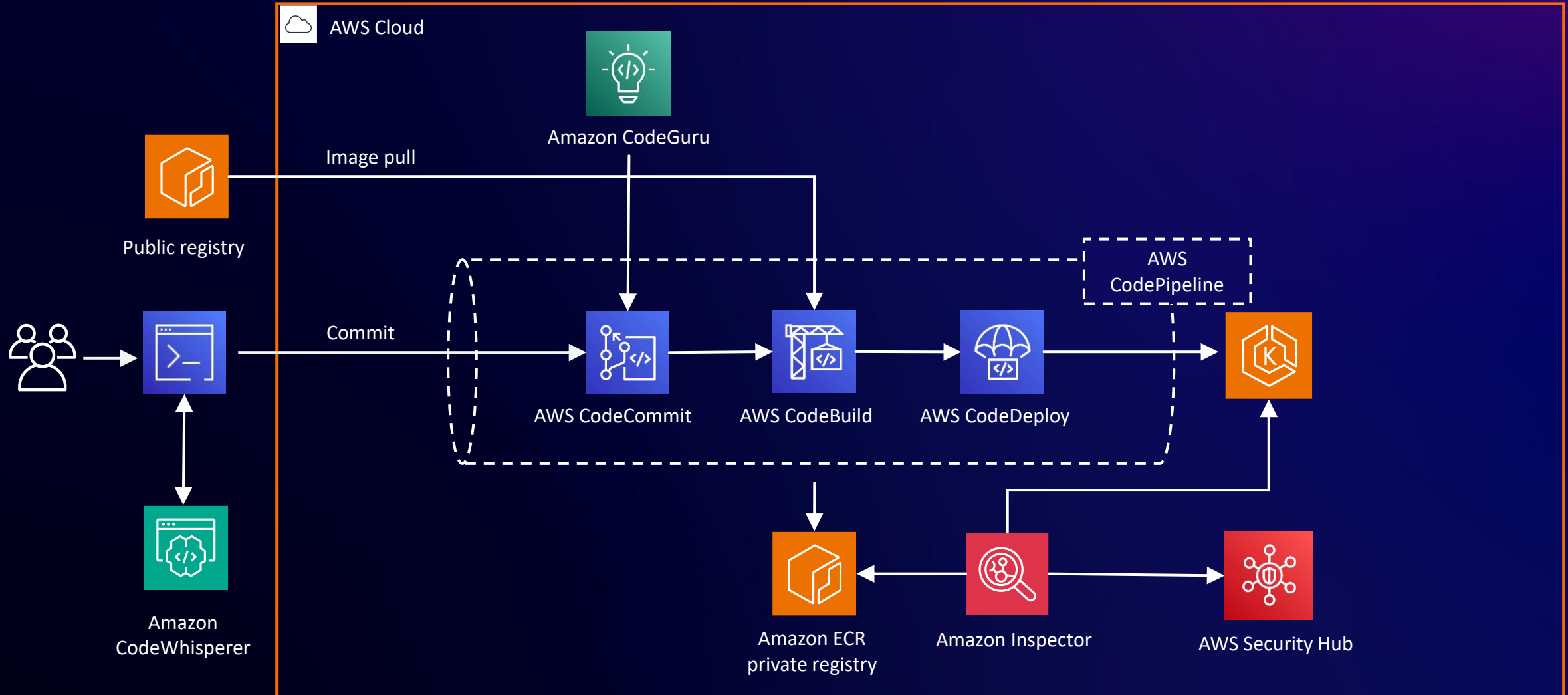
Security in development with AWS



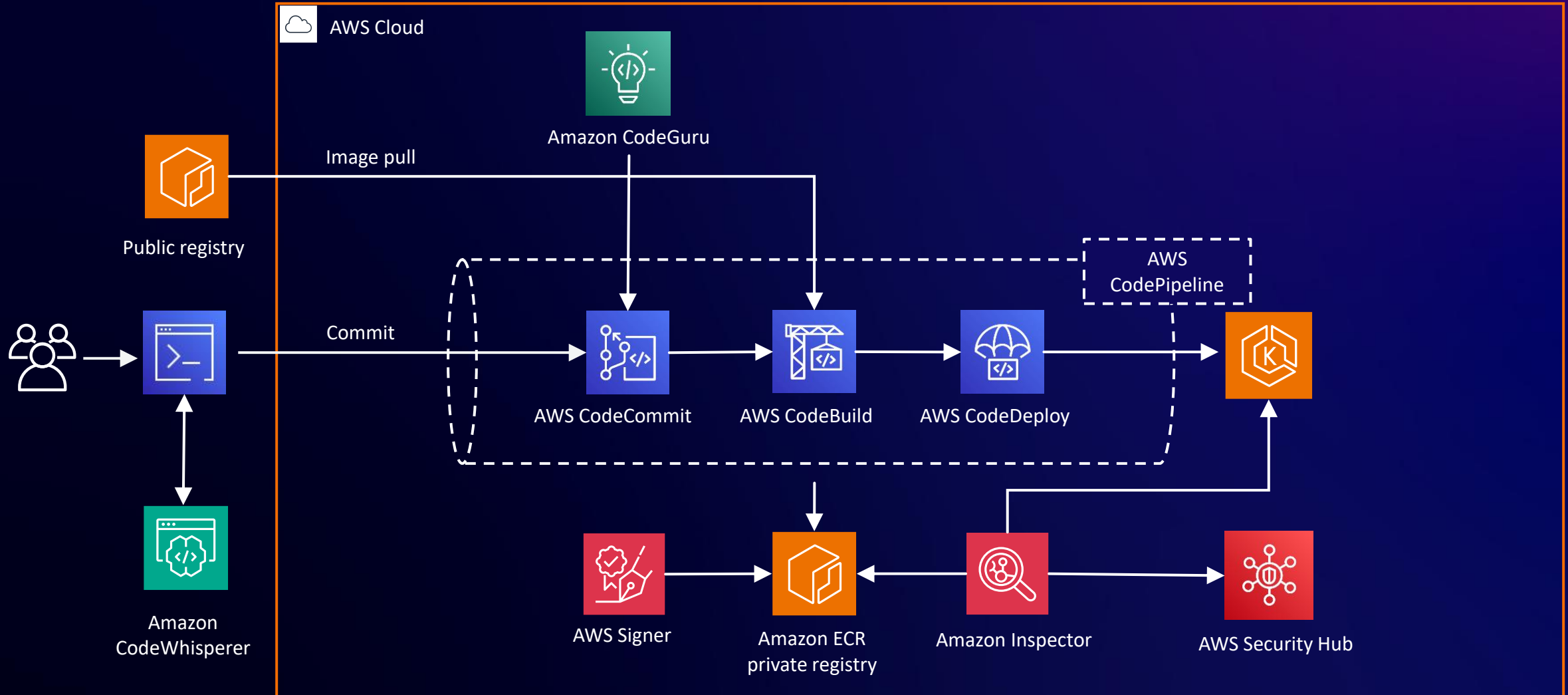
Security in development with AWS



Security in development with AWS



Security in development with AWS



Next steps

1. Turn on Amazon Inspector in just a few clicks
2. Try out Amazon CodeWhisperer, free for individual use
 - 50 security scans, per user, per month free
3. Try out AWS Signer, free for use with AWS Lambda and Amazon ECR
4. Check out the AWS Well-Architected Framework for
 - DevOps:
<https://docs.aws.amazon.com/wellarchitected/latest/devops-guidance>
 - Application security:
<https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/application-security.html>

Save the date for AWS re:Inforce

JUNE 10 – 12, 2024 | PHILADELPHIA, PA



AWS
re:Inforce



© 2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Thank you!



Please complete the session
survey in the mobile app

Nicholas Jaeger

jaegernj@amazon.com

 [linkedin.com/in/nickjaeger](https://www.linkedin.com/in/nickjaeger)

Niaz Khan

niazfk@amazon.com

 [linkedin.com/in/niaz-f-khan](https://www.linkedin.com/in/niaz-f-khan)